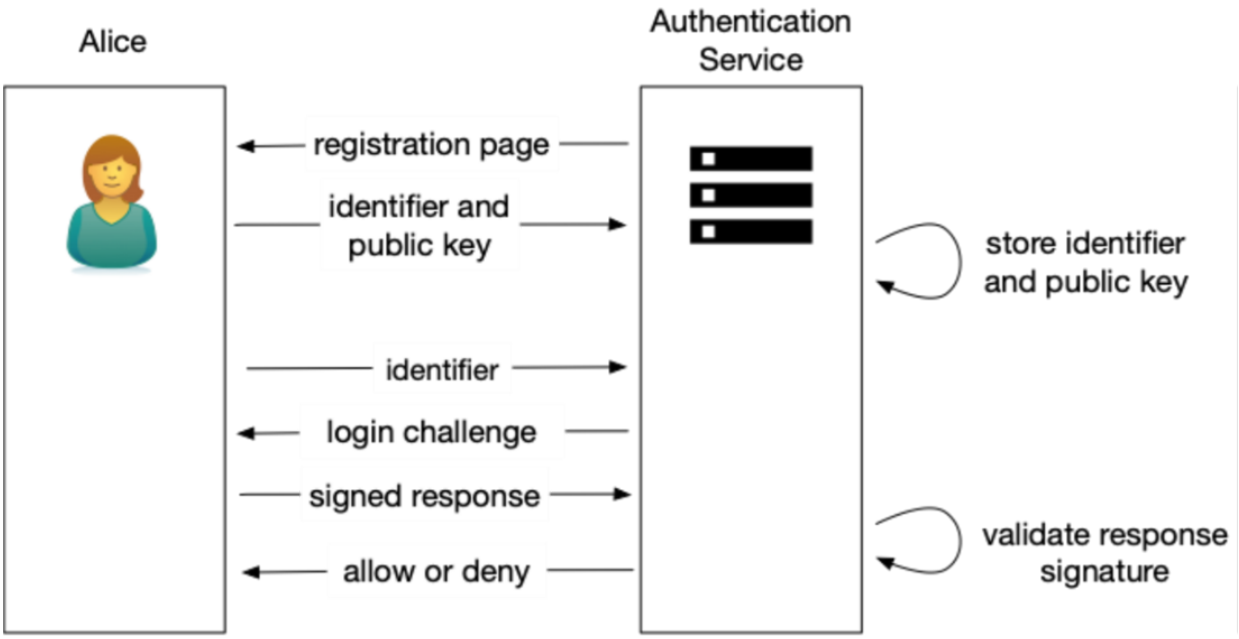


Figure 3.8 Challenge-response authentication flow using public-key cryptography. Alice registers by providing an identifier and a public key. At login, the service sends a challenge that Alice signs with her private key. The service verifies the signature using the stored public key, confirming her identity without exposing the private key. This method offers strong resistance to phishing and replay attacks.

During registration, Alice provides an identifier and a public key, which the authentication service stores. When Alice wants to authenticate, she provides only her identifier, and the service sends back a challenge. This can be any string depending on the specific protocol. Alice uses the private key that pairs with the public key she registered with the service to cryptographically sign the challenge and sends it back. The service can use her public key to verify the signature and know that Alice controls the private key matching the public key they've stored.

Note that Alice never shares her secret (the private key) with anyone. Because of how public-private cryptography works, she proves possession without ever having to reveal it. The authentication service can send a unique challenge each time Alice logs in, making the response impossible to replay and resistant to phishing since, even if intercepted, the attacker can't use it.